Stackify is now BMC. Read the Blog

Stackify a BMC company

Start Free Trial

Product Pricing Solutions Learn Login

Start Free Trial

# How to Incorporate Security Into Your company's SDLC

By: pjain@simpalm.com | July 24, 2020




It's been shown that if you follow a proven collection of practices for developing, designing, testing, implementing, and maintaining your software, you will produce a much higher quality product. Over the past few years, we have seen an increasing number of cases of attacks on the application layer. The Open Web Application Security Project, OWASP, estimates that around one-third of web applications contain security vulnerabilities. Security should always be considered from the beginning of the project until its conclusion. Thus, bringing security into the mainstream of the software development life cycle (SDLC) is important. Implementing a secured SDLC helps you to produce an application that is more likely to meet the needs of your users. You will be balancing the security of the application with performance and stability from the start of the project, until the completion of the project when you deliver the software.

# What is SDLC, and related security in the

Stackify
a BMC company
Start Free Trial
Product Pricing Solutions Learn Login
Start Free Trial

software. In other words, it provides a well-structured flow of phases to help companies efficiently produce software. With the software development life cycle, teams achieve one goal and then a new goal will be set and the team then works towards that goal. Development teams use different models such as Waterfall, Iterative, or Agile. However, all models usually follow these phases:

1. Conceptualizing or determining requirements and analysis

The first phase of SDLC is gathering requirements and analysis. This phase is the main focus for project managers and stakeholders as they address important questions such as who is going to use the system, how will they use the system, what data should be used as input into the system, and what will be the output of the system. In a secure SDLC, a sponsor initiates this activity and the development team is responsible for security training.

2. Planning

A requirement specification document is created to serve as a guideline for the planning phase of the SDLC. In the planning phase, the blueprint of the workflow is created and the development process sequence is determined. Threat modeling and third party software training are major activities in the planning phase. To ensure security, gap analysis, and privacy implementation assessment (PIA) are initiated by senior engineers and project managers under a secured SDLC model.

3. Design and Development

In this phase, a requirement document is gathered and used as input for creating the design of the software. Once the development team gets the design document, the software design is further translated into source code. All the components of the software are

implemented in this phase. To ensure security, a code review and

Stackify
a BMC company
Start Free Trial
Product Pricing Solutions Learn Login
Start Free Trial

testing starts once the coding is completed. The build modules are released for testing in this phase. The developed software is tested thoroughly with any defect found sent to the development team to get it fixed. Retesting is done until the software meets the customer requirements. The testing phase under a secured SDLC involves fuzzing done by developers, QA or security experts, and third-party penetration testing done by the third-party certified pen testers. Many QA are also beginning to implement APM tools like Stackify Retrace in their non-production environments as part of their testing process to go beyond functional testing.

5. Release

After successful testing, the software is released for users. Beta testing is performed as soon as the software is deployed. If any bugs are found, it will be given to the development team to fix it. Once all beta testing is done, the software is released for the final deployment. Final gap analysis, final security test review, final privacy review, and open source licensing review are major activities to perform under a secured SDLC model.

6. Sustain

The development team will continue to fix any issues or improve features. In this phase, external vulnerability disclosure and response and third-party software tracking and review is done by senior technical members or technical leads.

It is crucial to balance security with application performance and stability from the beginning until the completion of the project. Implementing an application performance management tool, such as Stackify Retrace, can assist with improving application performance and stability from nonprod to production environments. Try your free, two week trial of Retrace today

**How Each Security Activity Should Correlate with a Phase in**

Stackify
a BMC company
Start Free Trial
Product Pricing Solutions Learn Login
Start Free Trial

## Things to keep in mind while incorporating security into SDLC

**Awareness of secure coding practices**

It is important to educate your team on secure coding practices and to use the available framework for security while building and planning for test cases. Use code scanning tools such as Code Sight, AppScan Source, and Coverity.

**Performing gap analysis**

It is helpful to perform a gap analysis to find out the effectiveness of your organization's current activities and policies.

**Threat Modeling**

Threat modeling for software components is done to identify and manage the threats in the early development lifecycle. It is all about planning for the appropriate mitigation before it becomes more harmful. There can be different approaches for this activity, such as protecting specific critical processes, exploiting weaknesses, or focusing on the system design.

**Secured design with team review**

The development team should include security features while building software with developers including security design review when reviewing functional feature design. It is important to review code and developers need to be aware and follow a checklist of the most common coding security risks

**Open-Source Analysis**

Open-Source Analysis reduces vulnerabilities with the dependencies.

Stackify
a BMC company
Start Free Trial
Product Pricing Solutions Learn Login
Start Free Trial

It is one of the first secured SDLC models of its kind, proposed by Microsoft in association with the phases of a classic SDLC.

**NIST 800-64**

It was developed by the National Institute of Standards and technology to provide security measures within the SDLC.

## Conclusion

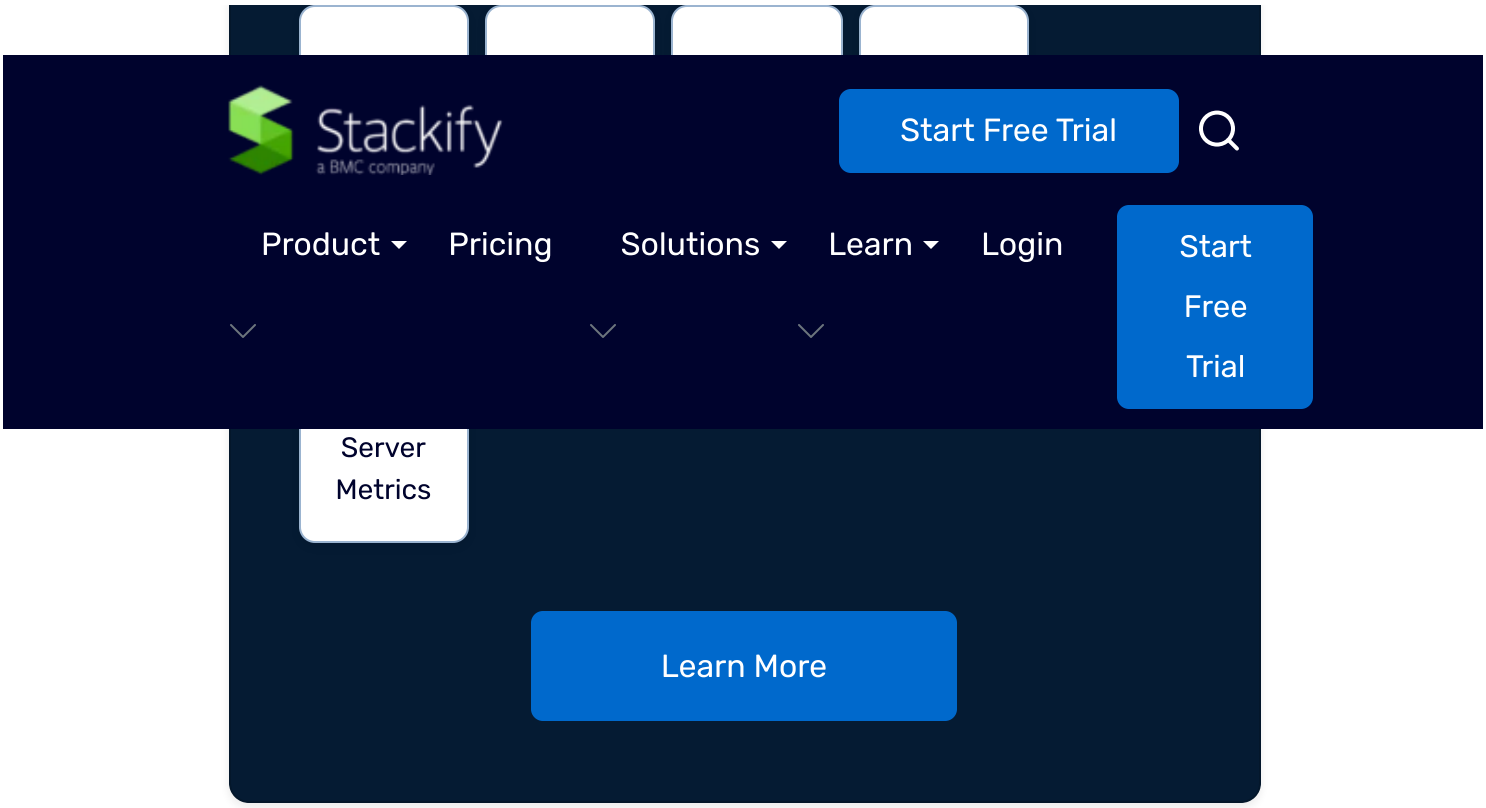
To ensure the security and quality of the entire SDLC, we need to take many important measures and use the right tools for the job along the way. It is much easier to track and fix the security issues by incorporating security functionality into the software application at the building stage.

### Related Posts:

**How we named Prefix: It was a little hairy**
**Software Development – A Team Sport**
**What is Code Profiling? Learn the 3 Types of Code Profilers**
**DevCheats – How to Write Better SQL Queries**
**How to Use Prefix to Troubleshoot Remote HTTP Calls**

**Improve Your Code with Retrace APM**

Stackify's APM tools are used by thousands of .NET, Java, PHP, Node.js, Python, & Ruby developers all over the world. Explore Retrace's product features to learn more.




Author

**pjain@simpalm.com**

More articles by pjain@simpalm.com

Search by topic

**Get the latest news, tips, and guides on software development.**

Join the community of 40,000 developers that subscribe to our

Stackify
a BMC company

Start Free Trial

Product Pricing Solutions Learn Login

Start Free Trial

By submitting your email address, you agree to be contacted via e-mail about our products and services. You can unsubscribe at any time.

## Popular Posts




**Performance Testing Types, Steps, Best Practices, and More**




**Learn Python: Tutorials for Beginners, Intermediate, and Advanced Programmers**




**Learn Java: Tutorials for Beginners, Intermediate, and Advanced Programmers**

**What are CRUD Operations: How CRUD Operations Work, Examples, Tutorials & More**

**Node.js Error Handling Best Practices: Ship With Confidence**

Stackify
a BMC company
Start Free Trial
Product Pricing Solutions Learn Login
Start Free Trial

Ruby agile agile methodology AI API apm APM for All application optimization application performance application profiling Application Programming

## Latest Posts

**Stackify Retrace Use Cases – Quality Assurance**

**Stackify Retrace Use Cases – Customer Support**

**What Is Powershell? An Introduction**

**Strategy Pattern: Definition, Examples, and Best Practices**

7171 Warner Ave
Suite B787
Huntington Beach, CA 92647

866-638-7361

## Connect With Us

## Products

Retrace
Prefix
Netreo
.NET Monitoring
Java Monitoring
PHP Monitoring
Node.js Monitoring
Ruby Monitoring
Python Monitoring
Retrace vs New Relic

## Solutions

Application Performance Management
Centralized Logging
Full Transaction Tracing
Error Tracking
Application & Server Monitoring
Real User Monitoring
Retrace Deployment Tracking
For DevOps

Retrace vs Application Insights



Blog
Documentation
Free eBooks
Free Webinars
Videos
Support

GDPR
Security Information
Terms & Conditions
Privacy Policy

2025 © Copyright. Stackify All rights reserved.